Diapositive de conformité : texte, preuves et notes orales

Livrable du track 1. La diapositive elle-même est `conformite-slide.pdf` (source : `conformite-slide.html`). Ce fichier porte son texte, la preuve derrière chaque ligne, les références relues à la source et ce qui se dit à l'oral. État du dépôt au 11 octobre 2026.

Elle répond aux deux questions du guide : comment la solution se place dans le cadre réglementaire, et comment un auditeur vérifie ses décisions.

Ce que nous ne disons pas : « conforme DORA », « conforme » à quoi que ce soit, « certifié », « anonymisé », « audité ».

Tableau de la diapositive

Texte	Ce que l'outil apporte	Ce que nous ne revendiquons pas
DORA, règlement (UE) 2022/2554, art. 17 à 19	Journal chaîné par empreintes : toute altération se détecte. Rapport d'incident prérempli, avec les horodatages d'arrivée, de détection, de pause et d'alerte. Alerte relevée 258 ms après l'arrivée à la porte d'entrée, 8,4 s par le contrat	La classification de l'incident et sa notification, qui restent à l'entité
AI Act, règlement (UE) 2024/1689, art. 12 et 14	Journalisation automatique de chaque étape. Contrôle humain appliqué par le contrat : approbation au-dessus du seuil, refus à l'échéance. Une pause ne se lève que par un humain	La qualification du système
MiCA, règlement (UE) 2023/1114	Démonstration sur notre L1 Avalanche de test, avec un jeton natif de test sans valeur. Aucun service sur crypto-actifs n'est rendu à un client	Le statut de prestataire de services sur crypto-actifs
LCB-FT, règlements (UE) 2024/1624 et 2023/1113	Chaîne d'autorité de chaque demande : agent, mandat, client, signataire, transaction. Bénéficiaire et montant inscrits à l'avance par un rôle séparé	La vérification d'identité, le filtrage des sanctions, les informations accompagnant un transfert

La preuve derrière chaque ligne

Affirmation	Preuve	Réserve
Journal chaîné	`specs/04-journal.md`, `response/src/journal.ts`, script `verify-journal`	Sans empreinte de tête gardée ailleurs, une troncature en fin de journal ou une réécriture complète passent inaperçues

Affirmation	Preuve	Réserve
Rapport prérempli et horodaté	`response/src/report.ts`, `specs/schemas/incident-report.schema.json`	Le montant exposé reste vide : le service ne lit pas les registres du contrat
Délais d'alerte	Deux rapports d'incident des scènes 3 et 4, jouées sur le L1 de test	Un incident par chemin. Ce sont des relevés, pas des moyennes
Contrôle humain au-dessus du seuil	`src/ArgentVault.sol`, fonctions `approve`, `refuse`, `expire` ; `docs-jury/tests.md`	Règle du contrat. L'identité de l'approbateur est une clé, pas une personne vérifiée
Pause levée par un humain	Test « seule une décision humaine lève une pause », `response/test/engine.test.ts`	L'auteur de la décision est déclaré, pas authentifié
L1 de test	`infra/l1/README.md`, `docs-jury/preuves/vault-l1-aws.md`	Un seul validateur. Jeton sans valeur
Chaîne d'autorité	Champ `authority_chain` du rapport d'incident ; signature EIP-712 vérifiée par le contrat	Le contrat vérifie le mandat déclaré de l'agent, pas son identité réelle
Montant et bénéficiaire inscrits à l'avance	Rôle d'admission du coffre, distinct du relais et de l'approbateur	Une fausse dette inscrite par l'admission serait payée

Comment un auditeur vérifie une décision

1. **Il prend l'identifiant de la demande.** La porte d'entrée l'attribue à l'arrivée. Il figure dans chaque entrée de journal et dans chaque rapport.
2. **Il relit l'événement `Decision` sur la chaîne** : décision, motif, bloc, horodatage. La décision se lit dans l'événement, jamais dans le statut du reçu.

   ```
   curl -s http://127.0.0.1:8787/decisions/<id>
   ```

   La réponse porte `tx_hash`, `log_index`, `block_number` et `block_timestamp`. Avec eux, l'auditeur relit l'événement sur le RPC du L1, sans passer par nos services.
3. **Il retrouve l'origine de la demande dans le journal** : agent, client, signataire, score et codes raison.

   ```
   curl -s "http://127.0.0.1:8790/journal/entries?request_id=
   <id>&limit=100"
   ```
4. **Il relance le script de vérification**, depuis `response/`, avec l'empreinte de tête portée par le rapport d'incident.

```
npm run verify-journal -- var/journal.jsonl --expect-head <empreinte>
--expect-seq <rang>
```

Code 0 : chaîne intègre et tête attendue. Code 1 : une entrée a été modifiée, retirée ou déplacée. Code 3 : la chaîne est cohérente, mais sa tête n'est pas celle du rapport.

5. **Il recalcule la règle à la main.**

```
plaçable = max(0, caisse − dettes admises − réserve de sécurité −
placements bloqués)
```

Les événements du contrat suffisent à refaire ce calcul.

Exemple joué sur le L1 de test, le 11 octobre 2026. Facture piégée passée sous le seuil du détecteur, score 45 sur 70. Bloc 448 : décision 0, motif `INVOICE_UNKNOWN`. Aucun événement `Paid`. Montant sorti : 0.

Réserves à dire à l'auditeur :

- Le RPC du L1 est privé et la synchronisation est réservée aux validateurs. L'auditeur reçoit un accès en lecture ; il ne synchronise pas son propre nœud. Sur une chaîne à plusieurs validateurs, un auditeur pourrait en opérer un : c'est une piste, pas un fait.
- Le journal prouve l'intégrité de ce qui a été écrit, pas sa vérité.
- Aucune authentification entre nos services : ils n'écoutent que sur la machine locale.
- Le journal est « au moins une fois » : une entrée peut y figurer deux fois, jamais zéro.

Références relues à la source

Relues le 11 octobre 2026 sur EUR-Lex, dans le texte publié d'origine.

Texte	Référence	Ce qu'elle dit
DORA	Règlement (UE) 2022/2554, art. 17, 18, 19	Gestion, classification et notification des incidents majeurs liés aux TIC. Applicable depuis le 17 janvier 2025
DORA, délais	Règlement délégué (UE) 2025/301, art. 5	Notification initiale : 4 h après la classification en incident majeur, 24 h au plus après la prise de connaissance. Rapport intermédiaire : 72 h après la notification initiale. Rapport final : un mois après le rapport intermédiaire
DORA, prestataires tiers	Règlement (UE) 2022/2554, art. 28 à 30	Risque lié aux prestataires tiers de services TIC, clauses contractuelles
AI Act	Règlement (UE) 2024/1689, art. 12 et 14	Tenue de journaux et contrôle humain, pour les systèmes à haut risque

Texte	Référence	Ce qu'elle dit
AI Act, annexe III	Même règlement	Un agent de paiement d'entreprise n'y figure pas. Les entrées financières visent la solvabilité des personnes physiques et l'assurance vie et santé
MiCA	Règlement (UE) 2023/1114, art. 3 et 59	Définition et agrément du prestataire de services sur crypto-actifs. Applicable depuis le 30 décembre 2024
LCB-FT	Règlement (UE) 2024/1624	Règlement anti-blanchiment. Applicable le 10 juillet 2027
Transferts de crypto-actifs	Règlement (UE) 2023/1113, art. 14	Informations accompagnant un transfert. Applicable depuis le 30 décembre 2024

Non vérifié : un report des obligations « haut risque » de l'AI Act a été proposé par la Commission. Son adoption n'a pas été relue. Ne citer aucune date d'application de l'AI Act à l'oral.

Notes orales

- Ouvrir par la phrase du haut : nous ne revendiquons rien, nous apportons des preuves.
- DORA : l'entité notifie, pas nous. Notre rapport lui donne les horodatages dont elle a besoin dans les premières heures.
- AI Act : les articles 12 et 14 visent les systèmes à haut risque. Un agent de paiement d'entreprise n'y figure pas d'office. Nous reprenons ces deux exigences comme une bonne pratique, sans qualifier le système.
- Montrer l'exemple du bloc 448 : c'est une décision réelle, relisible.
- Finir par la phrase du bas : le détecteur propose, la règle décide, l'humain tranche les exceptions.

Réponse à « si votre modèle se trompe, qui est responsable ? »

Le détecteur propose, il ne décide pas. La règle approuvée par le propriétaire du coffre décide : une facture se règle une seule fois, au bénéficiaire inscrit, pour le montant inscrit. Chaque décision est tracée avec son motif. La perte est bornée, pas nulle : une fausse dette inscrite par l'admission peut être réglée. Les exceptions passent par un humain. Le partage juridique de la responsabilité n'est pas tranché par l'outil.

Questions ouvertes

1. **Sommes-nous un prestataire tiers de nos clients ?** Si un client est une entité financière, l'outil pourrait relever de ses prestataires de services TIC au sens de DORA (art. 28 à 30). C'est une déduction, à poser à un juriste.
2. **Le statut du jeton.** Vendre des VETO contre de la monnaie fiduciaire pose la question de leur qualification au regard de MiCA. Non étudiée.
3. **Le connecteur bancaire.** En production, l'événement `Paid` serait l'autorisation qu'un connecteur bancaire consomme. Le contrat ne détiendrait plus les fonds, et la question réglementaire changerait de nature. Ce connecteur n'existe pas.